

پلتفرم متمرکز مدیریت، کنترل و توزیع امن Artifact و Container Image

Nexus Repository + Portal + PostgreSQL + Monitoring

این سند برای تصمیم‌گیری مدیریتی درباره رسمی‌سازی و عملیاتی‌سازی یک پلتفرم داخلی مدیریت Artifact تهیه شده است؛ پلتفرمی که فراتر از یک Mirror Registry ساده عمل می‌کند و کنترل متمرکز، انتشار کنترل‌شده، دسترسی امن، ثبت رویدادها و مسیر توسعه DevSecOps را در یک معماری Dockerized فراهم می‌سازد.

ارزش اصلی

کاهش وابستگی عملیاتی به رجیستری‌های بیرونی و ایجاد نقطه کنترل داخلی برای Pull و Push.

تصمیم موردنیاز

تایید رسمی‌سازی پلتفرم به عنوان سرویس زیرساختی مدیریت‌شده.

دامنه تأییدشده

Nexus, Portal, PostgreSQL Security Center, Artifact Monitoring و Publishing

درخواست تصمیم

تصویب ادامه تثبیت، بهره‌برداری و توسعه کنترل‌شده پلتفرم به عنوان مرجع داخلی توزیع Image و Artifact، همراه با الزام به تکمیل سیاست‌های امنیتی، Backup/Restore دوره‌ای، TLS و اتصال تدریجی به CI/CD.

مساله‌ای که پروژه حل می‌کند

در محیط‌های توسعه، عملیات و شبکه‌های محدود، اتکا به رجیستری‌ها و مخازن بیرونی تنها یک موضوع سرعت نیست؛ این وابستگی می‌تواند منبع شکست استقرار، نبود مالکیت روی نسخه‌ها، ضعف در کنترل دسترسی و کاهش قابلیت ردیابی باشد.

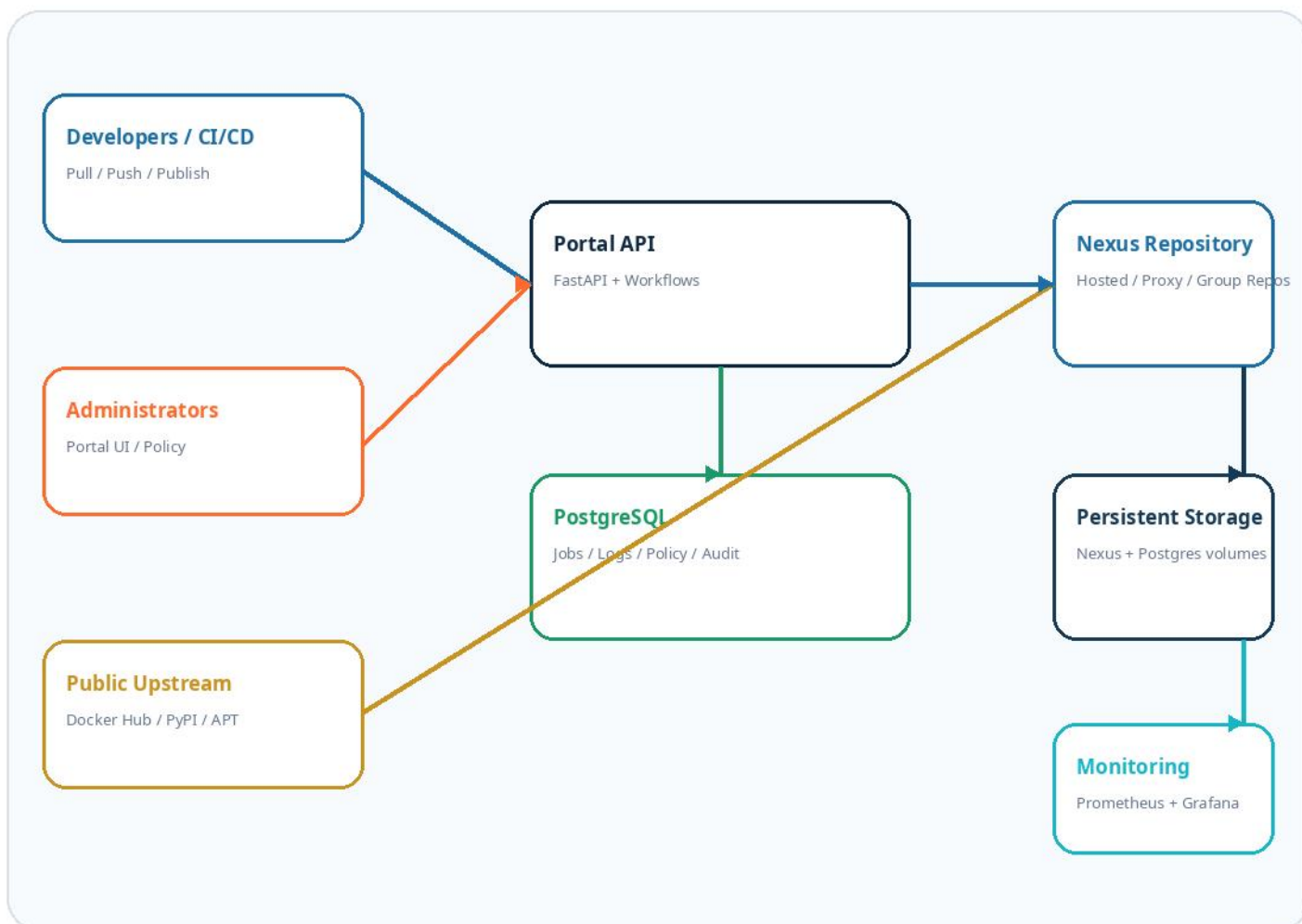
Current Problem	Operational Impact	Management Risk
وابستگی تکراری به Docker Hub و مخازن عمومی	کندی، خطا یا توقف Pull در زمان استقرار	وابستگی به سرویس‌های خارج از کنترل سازمان
نبود نقطه متمرکز برای Push داخلی	پراکنده شدن Image های داخلی و نسخه‌های عملیاتی	ضعف مالکیت و دشواری بازیابی نسخه‌ها
Anonymous Access یا دسترسی بدون سیاست مشخص	امکان استفاده افراد یا سیستم‌های غیرمجاز از Mirror	ریسک امنیتی و نبود پاسخگویی
نبود تاریخچه منسجم برای انتشار Artifact	دشواری پیگیری خطا، Digest، Checksum و خروجی کارها	کاهش قابلیت Audit و تصمیم‌گیری فنی
رشد کنترل نشده داده و Cache	مصرف Storage و دشواری Cleanup	هزینه عملیاتی و ریسک پر شدن دیسک

جمع‌بندی مدیریتی

یک Mirror Registry ساده برای افزایش سرعت Pull مفید است، اما برای مدیریت مالکیت، انتشار داخلی، کنترل کاربر و گروه، محدودسازی Backup/Restore، Audit Log، IP، و تصمیم‌گیری عملیاتی کافی نیست. نیاز واقعی، یک پلتفرم داخلی با سیاست، فرآیند و قابلیت مدیریت مرکزی است.

معماری پلتفرم داخلی Artifact

پروژه فعلی یک استقرار Dockerized چندسروپسی ارائه می‌کند که Portal را به Docker Engine، Nexus REST API، ابزارهای دریافت Package و PostgreSQL متصل می‌کند. داده‌های عملیاتی Portal در PostgreSQL نگهداری می‌شود و Nexus مسئول نگهداری Repository ها و Artifact ها است.



جریان Pull/Proxy

در صورت استفاده از Proxy Repository، درخواست‌ها از Nexus عبور کرده و در Cache داخلی ذخیره می‌شوند.

جریان Push/Hosted

Image ها و Package های داخلی از Portal یا Docker Client به Hosted Repository منتقل می‌شوند.

مرز امنیتی

Security Center نقش‌ها، کاربران، IP/CIDR و Anonymous Access را به صورت متمرکز مدیریت می‌کند.

مقایسه مستقیم: Mirror ساده در برابر پلتفرم داخلی مدیریت شده

Mirror Registry برای Cache کردن Pull ها ارزشمند است، اما هدف این پروژه ایجاد حاکمیت عملیاتی و امنیتی روی توزیع Artifact است. جدول زیر فقط قابلیت‌هایی را به عنوان Implemented نشان می‌دهد که در پروژه فعلی تایید شده‌اند.

معیار	Basic Mirror Registry	Nexus Internal Platform
هدف اصلی	Pull acceleration	Governance + controlled distribution
Private Push / Hosted	Limited / manual	Implemented: docker-hosted, PyPI, APT, raw
Proxy / Cache	Core capability	Available via Nexus proxy repos
Repository Group	Often absent	Implemented / configurable in Nexus
Authentication	Basic or optional	Implemented: Portal auth + Nexus users
RBAC	Limited	Implemented: groups, roles, permissions
Anonymous lockdown	Not central	Implemented via Security Center sync
Trusted IP/CIDR	Usually external	Implemented: preview/apply firewall policy
Publishing workflow	Not provided	Implemented: Docker, archive, Python, Debian jobs
Audit / logs	Minimal	Implemented: audit log, job logs, history
Backup / Restore	External task	Scripts provided for Nexus/PostgreSQL/config
Monitoring	External task	Prometheus/Grafana stack configured
Vulnerability scanning	Not inherent	Planned/recommended; Gripe flag exists
High Availability	Not inherent	Future phase / not confirmed

نتیجه: Mirror ساده یک قابلیت فنی برای Cache است؛ پلتفرم پیشنهادی یک سرویس زیرساختی برای مالکیت، سیاست‌گذاری، انتشار، ردیابی و کنترل دسترسی Artifact ها است.

ارزش پیشنهادی برای سازمان

مزیت پروژه در ترکیب چند قابلیت عملیاتی است: Repository Manager، Portal، Artifact، ذخیره پایدار، گزارش و نظارت. این ترکیب ریسک‌های عملیاتی را کاهش می‌دهد و یک مسیر قابل توسعه برای DevSecOps ایجاد می‌کند.

ارزش عملیاتی

Pull های تکراری سریع‌تر و قابل اتکاتر، کاهش وابستگی به Upstream، منبع استاندارد برای استقرار، و نگهداری داخلی Image ها و Package ها.

امنیت و حاکمیت

مدیریت کاربر/گروه، RBAC، محدودسازی Anonymous، سیاست‌های امنیتی. Access، Trusted IP/CIDR، Audit Log و امکان توسعه

توانمندسازی DevOps

آمادگی اتصال به CI/CD، تفکیک Repository ها، انتشار کنترل‌شده Docker Image، Python Package و Debian Package از Portal.

ارزش مدیریتی

مالکیت سرویس مشخص، شفافیت وضعیت، مسیر Roadmap قابل اندازه‌گیری، کاهش عدم قطعیت عملیاتی و امکان کنترل رشد Artifact ها.

قابلیت‌های تایید شده کلیدی

Dockerized Stack

Nexus, Portal, PostgreSQL, Traefik, Prometheus, Grafana

Portal State

Jobs, logs, publishing history, security policy, audit records

Artifact Publishing

Docker by name, Docker archive, Python fetch, Debian fetch

Security Center

Groups, users, permissions, IP rules, Nexus sync, firewall preview/apply

Operations

Health checks, persistent volumes, logging limits, backup/restore scripts

وضعیت فعلی و واقعیت‌های اجرایی

Current Status

Completed

معماری Health Check و Docker Compose، Nexus، PostgreSQL، Portal، Monitoring ها در مخزن تعریف شده‌اند.

Completed

Artifact Publishing و Security Center در Portal پیاده‌سازی شده و API‌های مرتبط وجود دارند.

Completed

Audit Log، Backup/Restore scripts، گزارش‌ها و Job Logs در ساختار پروژه وجود دارند.

Pending validation

آزمون دوره‌ای Restore، ظرفیت‌سنجی Storage و تست بار برای محیط تولید باید formalize شود.

Future phase

HA، TLS، سازمانی، Vulnerability Scanning اجباری و Signing/Policy enforcement باید در فازهای بعدی تکمیل شوند.

ریسک‌های کلیدی و کاهش ریسک

Single-node dependency

تعریف Backup/Restore آزمون‌شده، برنامه DR و بررسی HA در فاز بعد.

Storage growth

Retention Policy و Cleanup Policy برای Cache و Hosted Repository ها.

Credential protection

استفاده از Secrets، PORTAL_ADMIN_PASSWORD_HASH، امن و حذف رمزهای plaintext.

TLS and certificates

فعال‌سازی HTTPS، Secure Cookies و گواهی معتبر برای محیط تولید.

Vulnerability gap

فعال‌سازی Gype یا ابزار سازمانی و Block policy برای Critical/High در فاز امنیتی.

Firewall lockout risk

الزام افزودن IP مدیر و CI/CD قبل از Apply IP Firewall و استفاده از Preview.

Roadmap پیشنهادی

1

Stabilization

سخت‌سازی تنظیمات،
تست End-to-End،
Restore test

2

Governance

نهایی‌سازی RBAC،
Repository ownership،
Retention

3

CI/CD

اتصال Pipeline ها و
Push/Pull استاندارد

4

Security

Vulnerability
Scanning، Signing
Policy enforcement

5

Scale / DR

DR، Capacity یا HA
planning، مانیتورینگ
داخلی SLA

شاخص‌های موفقیت و تصمیم‌مدیریتی

برای تبدیل پروژه به سرویس زیرساختی مدیریت‌شده، موفقیت باید با شاخص‌های قابل اندازه‌گیری و نه صرفاً نصب نرم‌افزار سنجیده شود. مقادیر زیر به‌عنوان KPI پیشنهادی مطرح می‌شوند و نیازمند تعیین Baseline در آغاز بهره‌برداری هستند.

Internal Pull Share

درصد Pull هایی که از رجیستری داخلی سرو می‌شوند

Cache Hit Ratio

نسبت درخواست‌های پاسخ‌داده‌شده از Cache داخلی

Backup Success

نرخ موفقیت Backup و Restore test دوره‌ای

Unauthorized Attempts

تعداد تلاش‌های دسترسی غیرمجاز و روند آن

Managed Repositories

تعداد Repository های مدیریت‌شده و دارای مالک

CI/CD Adoption

تعداد Pipeline های متصل به Registry داخلی

Retention Compliance

میزان رعایت Retention/Cleanup Policy

Failed External Pulls

کاهش خطاهای استقرار ناشی از Upstream

Requested Decision

تصویب رسمی‌سازی، تثبیت و عملیاتی‌سازی Nexus Internal Registry Platform به‌عنوان سرویس زیرساختی مدیریت‌شده برای کنترل، توزیع و حاکمیت Artifact های داخلی.

اقدامات فوری پیشنهادی

- تأیید مالک سرویس، دامنه استفاده اولیه و سیاست دسترسی تیم‌ها.
- اجرای تست کامل Backup/Restore و مستندسازی Runbook عملیاتی.
- فعال‌سازی HTTPS/TLS و hardening رمزها و Cookie ها برای تولید.
- تعریف Retention/Cleanup Policy و ظرفیت‌سنجی Storage.
- اتصال مرحله‌ای CI/CD و فعال‌سازی کنترل‌های امنیتی فاز بعد.

جمع‌بندی: انتخاب یک Mirror ساده مشکل سرعت Pull را تا حدی کاهش می‌دهد؛ اما این پروژه پایه یک پلتفرم حاکمیتی و عملیاتی است که می‌تواند منبع استاندارد، امن و قابل ردیابی برای Image و Artifact های سازمان باشد.